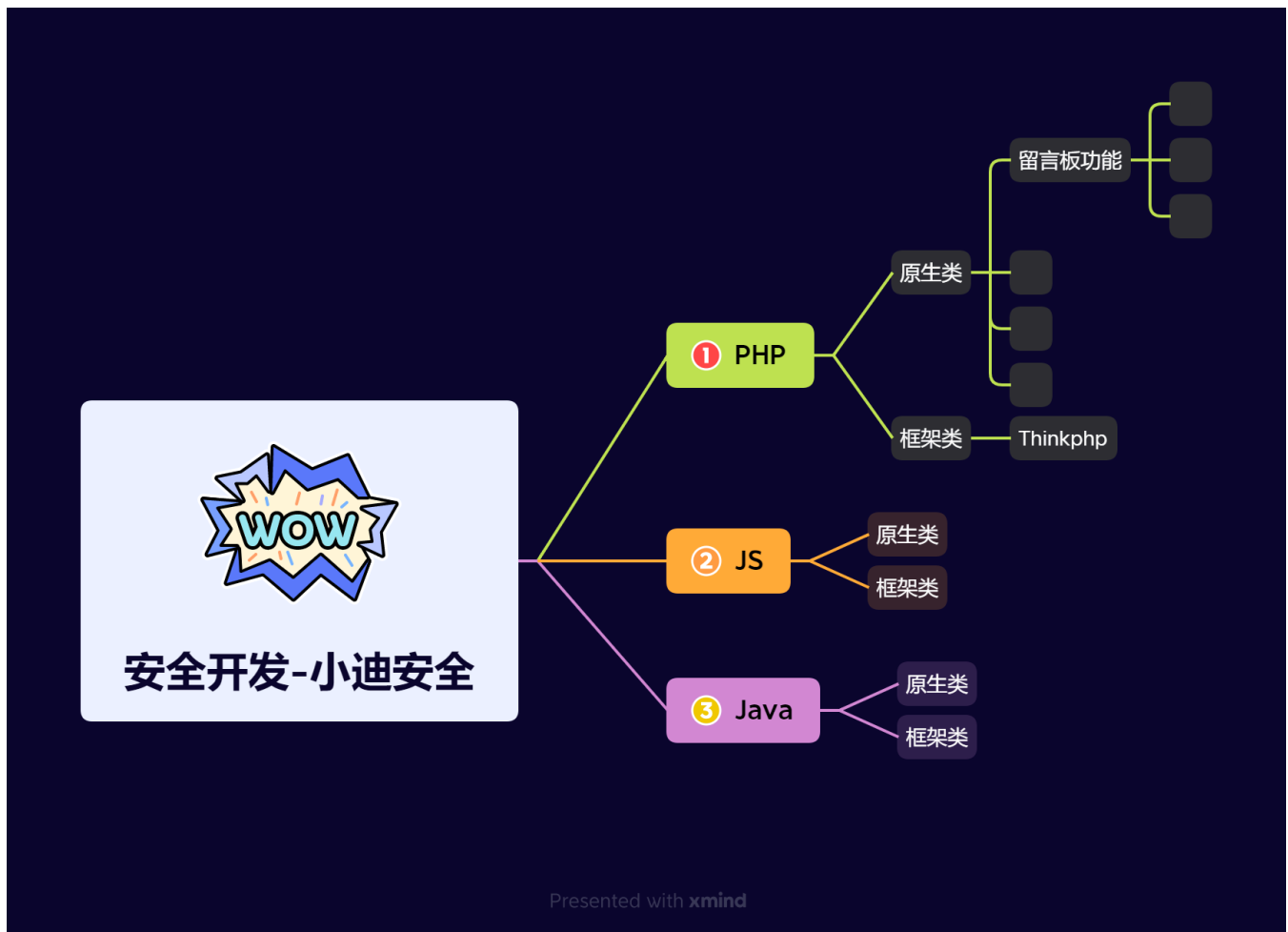


Day28 安全开发-JS应用&原生开发&JQuery库&Ajax技术&前端后端&安全验证处理



1.知识点

- 1、PHP留言板前后端功能实现
- 2、数据库创建&架构&增删改查
- 3、内置超全局变量&HTML&JS混编
- 4、第三方应用插件&传参&对象调用

-
- 1、PHP后台身份验证模块实现
 - 2、Cookie&Session技术&差异
 - 3、Token数据包唯一性应用场景
 - 项目1：用cookie做后台身份验证
 - 项目2：用session做后台身份验证
 - 项目3：用token做用户登录判断
-

- 1、PHP文件管理-显示&上传功能实现
 - 2、文件上传-\$_FILES&过滤机制实现
 - 3、文件显示-目录遍历&过滤机制实现
-

- 1、PHP文件管理-下载&删除功能实现
 - 2、PHP文件管理-编辑&包含功能实现
-

- 1、PHP新闻显示-数据库操作读取显示
 - 2、PHP模版引用-自写模版&Smarty渲染
 - 3、PHP模版安全-RCE代码执行&三方漏洞
-

- 1、TP框架-开发-路由访问&数据库&文件上传&MVC模型
 - 2、TP框架-安全-不合规写法&内置过滤绕过&版本安全漏洞
-

- 1、JS应用-原生态开发&第三库开发
 - 2、JS功能-文件上传&登录验证&商品购买
-

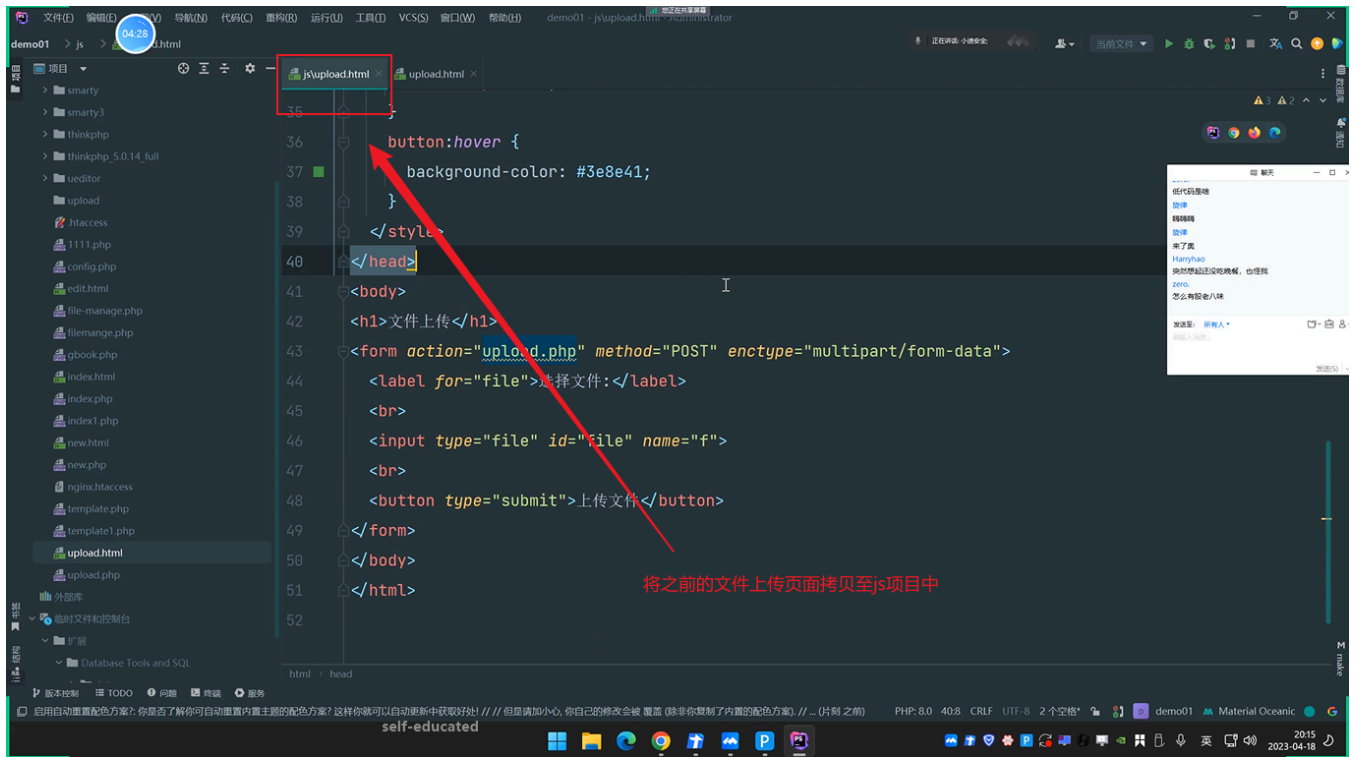
2.演示案例

- 
- 1 1、原生JS教程
<https://www.w3school.com.cn/js/index.asp>
 - 2 2、jQuery库教程
<https://www.w3school.com.cn/jquery/index.asp>

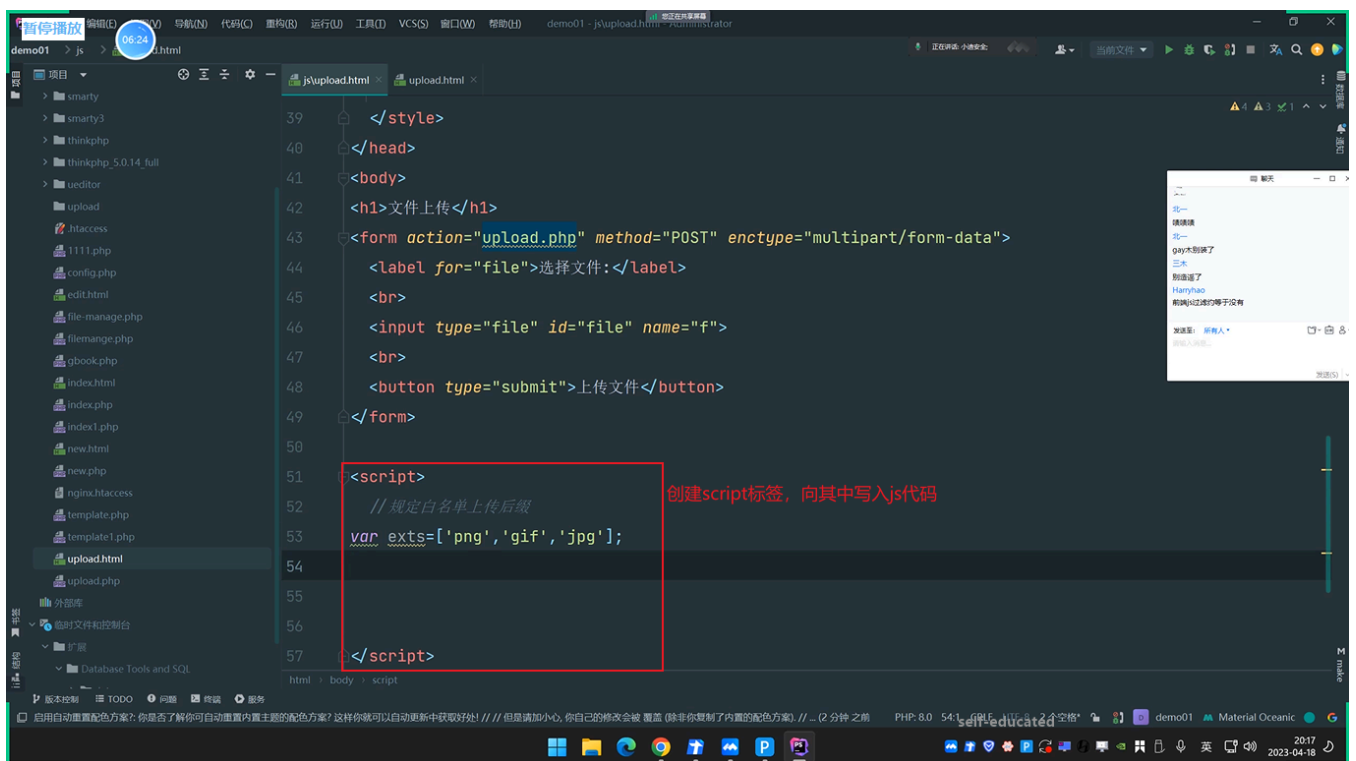
2.1 JS原生开发-文件上传-变量&对象&函数&事件

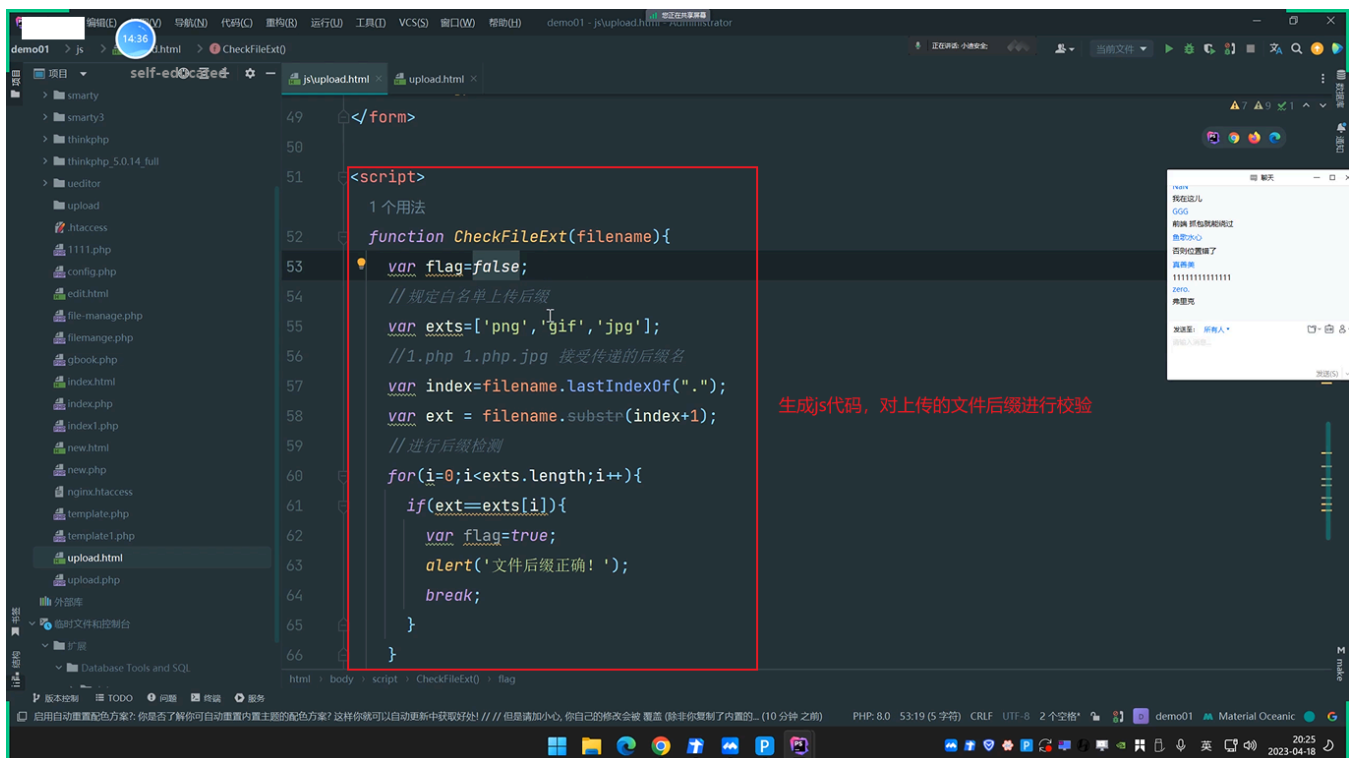
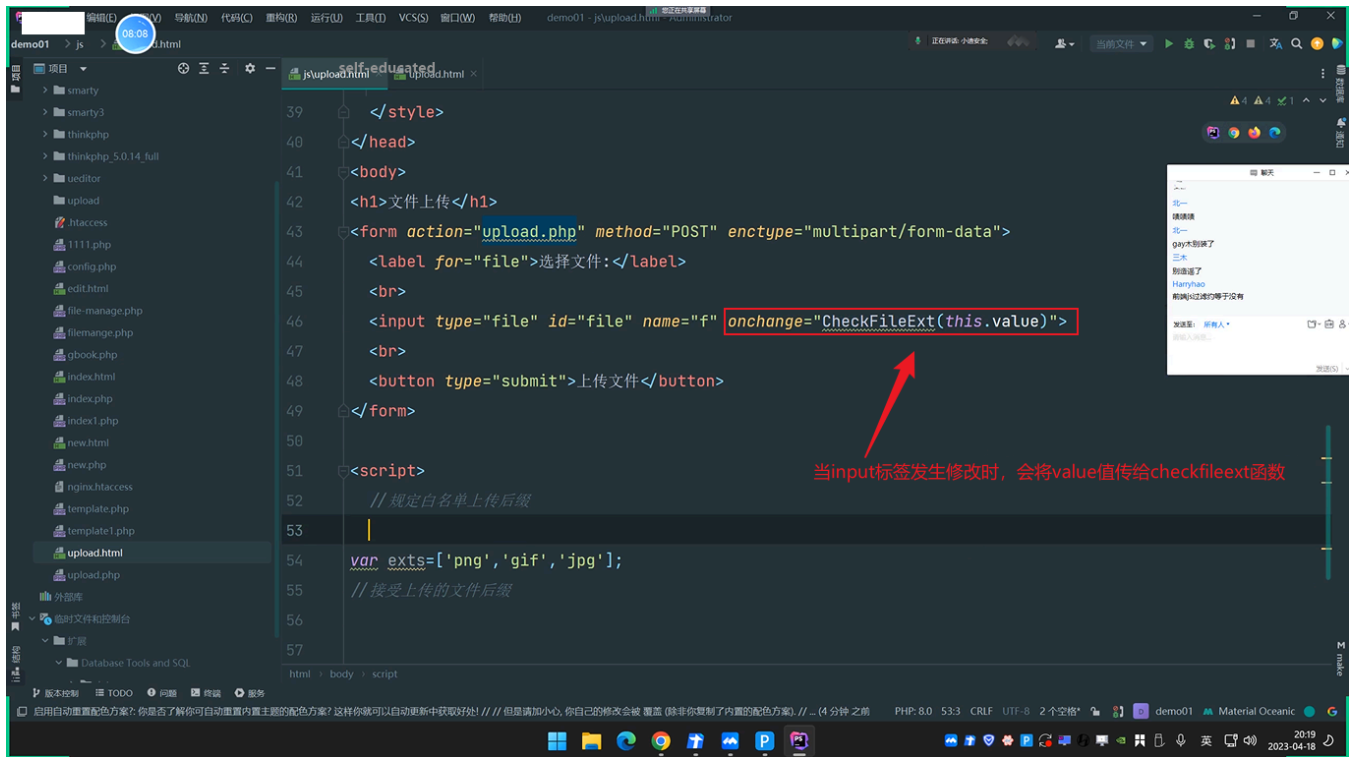
- 
- 1 1、布置前端页面
 - 2 2、JS获取提交数据
 - 3 3、JS对上传格式判断
 - 4 4、后端对上传数据处理
 - 5 前端JS进行后缀过滤，后端PHP进行上传处理
 - 6 架构：html js php - upload.php
 - 7 安全问题：
 - 8 1、过滤代码能看到分析绕过
 - 9 2、禁用JS或删除过滤代码绕过

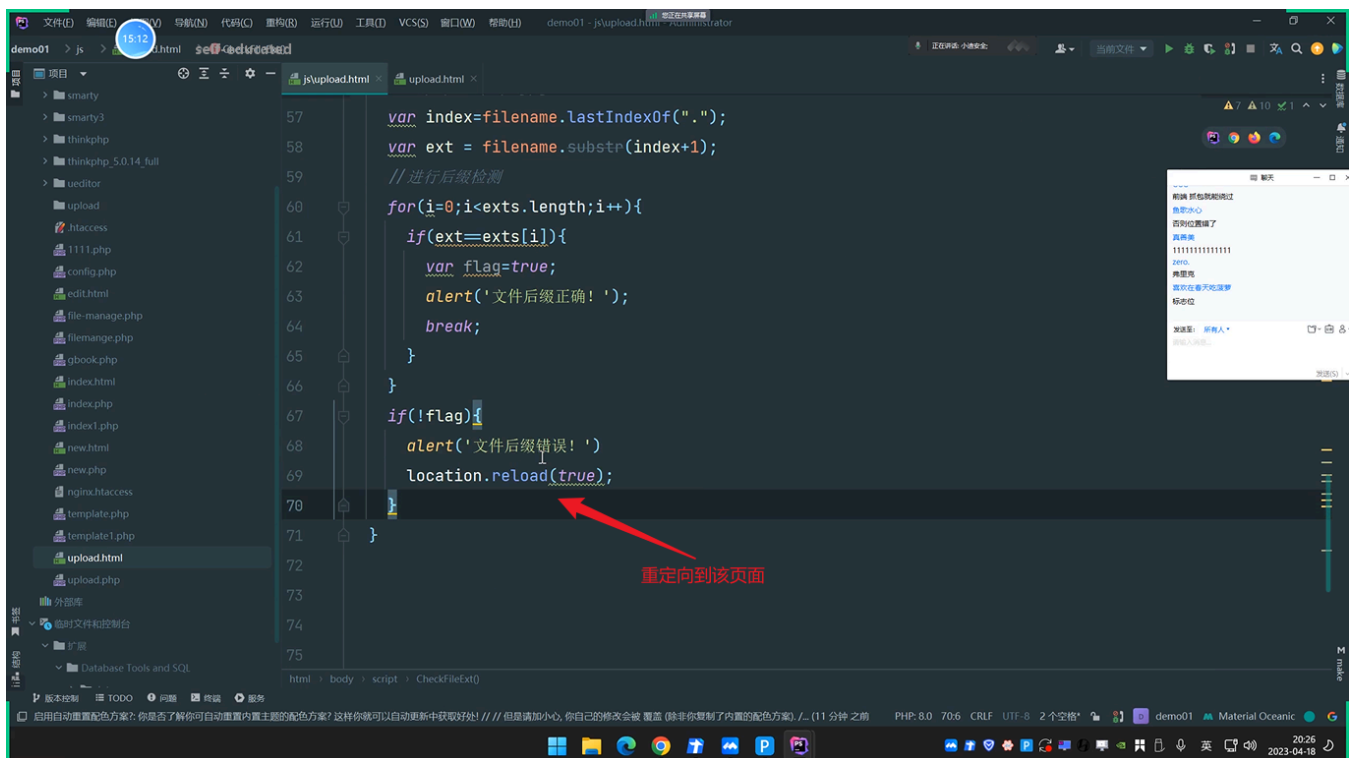
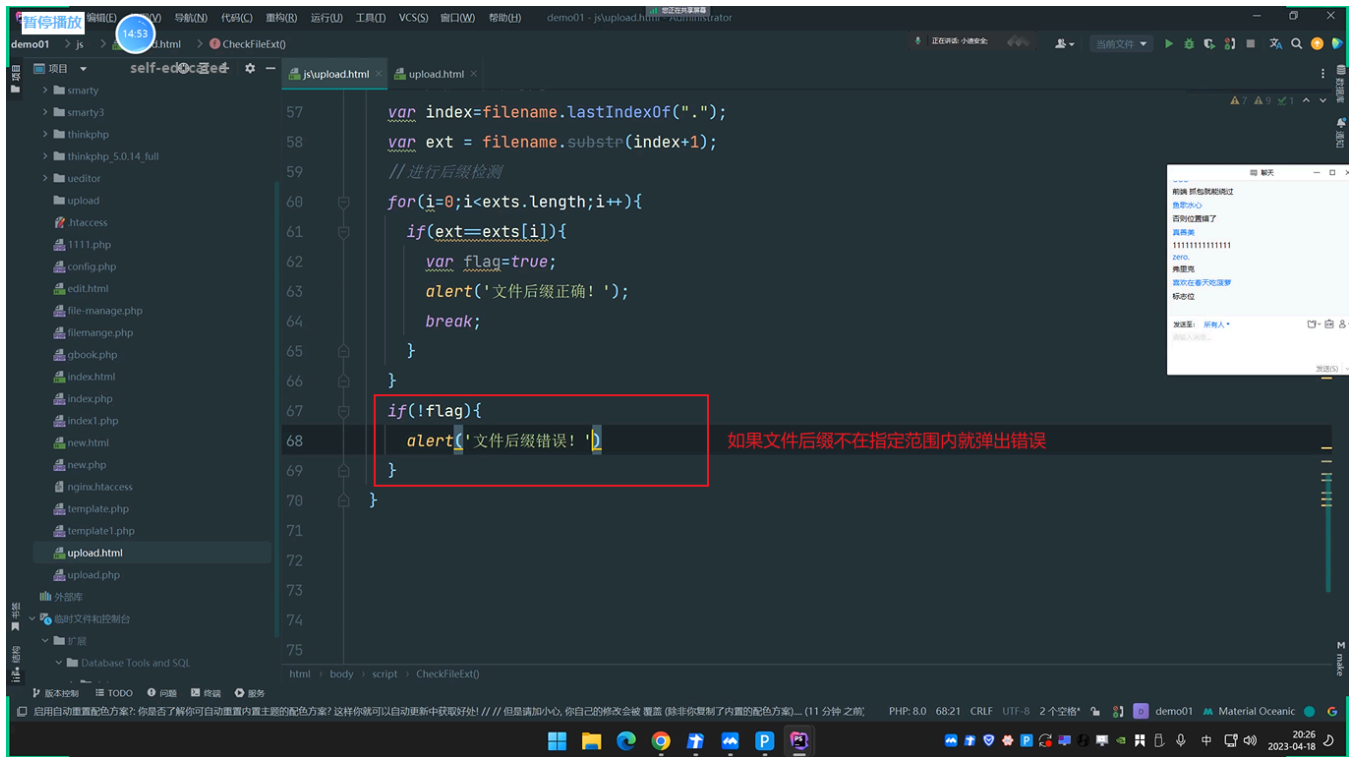
(1) 布置前端页面：



(2) JS获取提交数据&&JS对上传格式判断:







(3) 后端对上传数据处理:

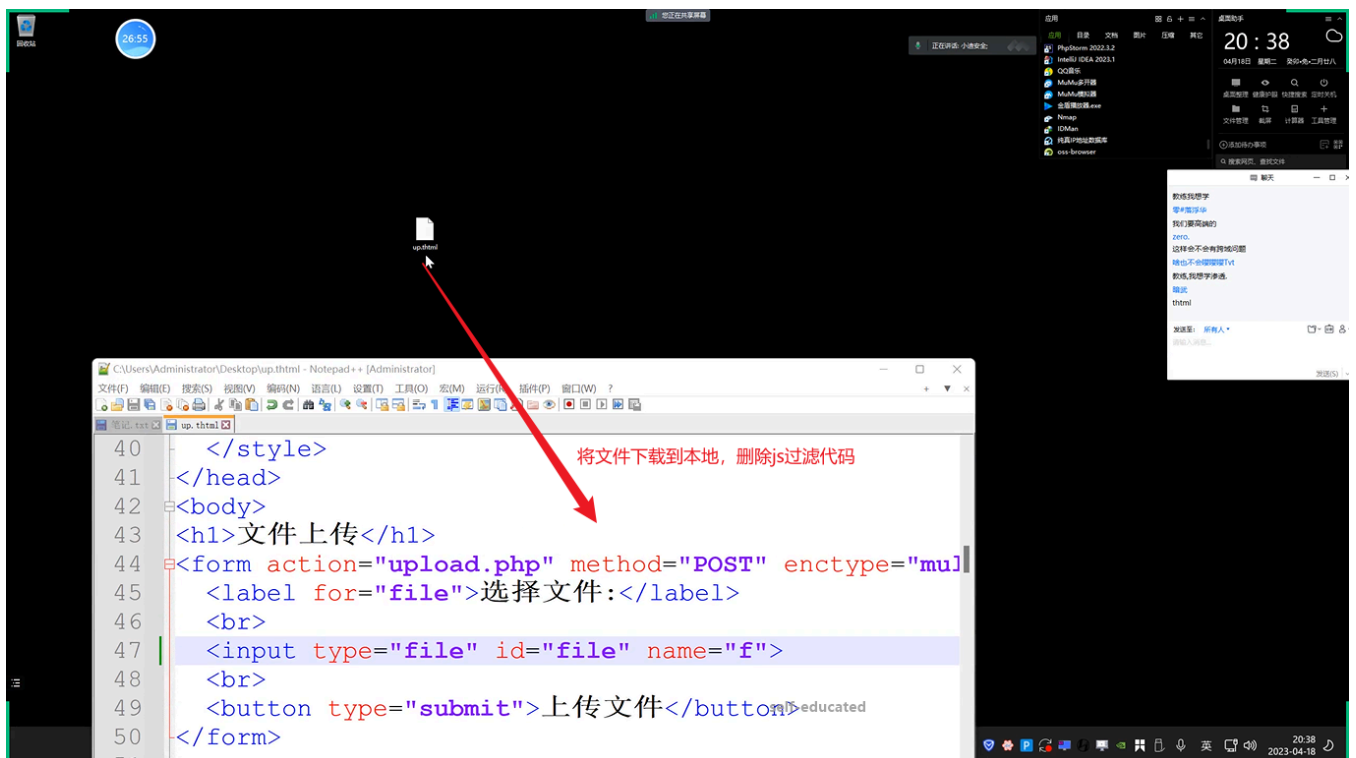
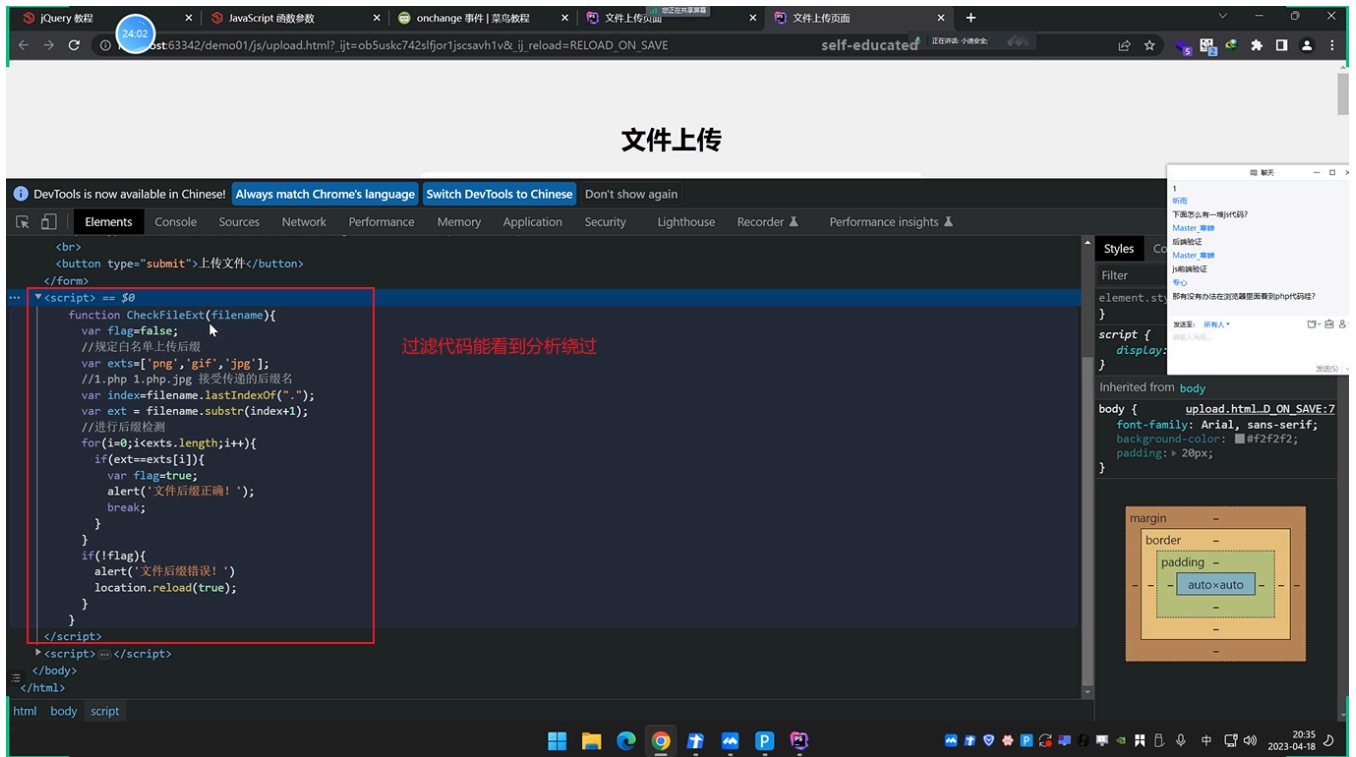
```
35 }
36 button:hover {
37     background-color: #3e8e41;
38 }
39 </style>
40 </head>
41 <body>
42 <h1>文件上传</h1>
43 <form action="upload.php" method="POST" enctype="multipart/form-data">
44     <label for="file">选择文件:</label>
45     <br>
46     <input type="file" id="file" name="f" onchange="CheckFileExt(this.value)">
47     <br>
48     <button type="submit">上传文件</button>
49 </form>
50
51 <script>
52     1个用法
53     function CheckFileExt(filename){
```

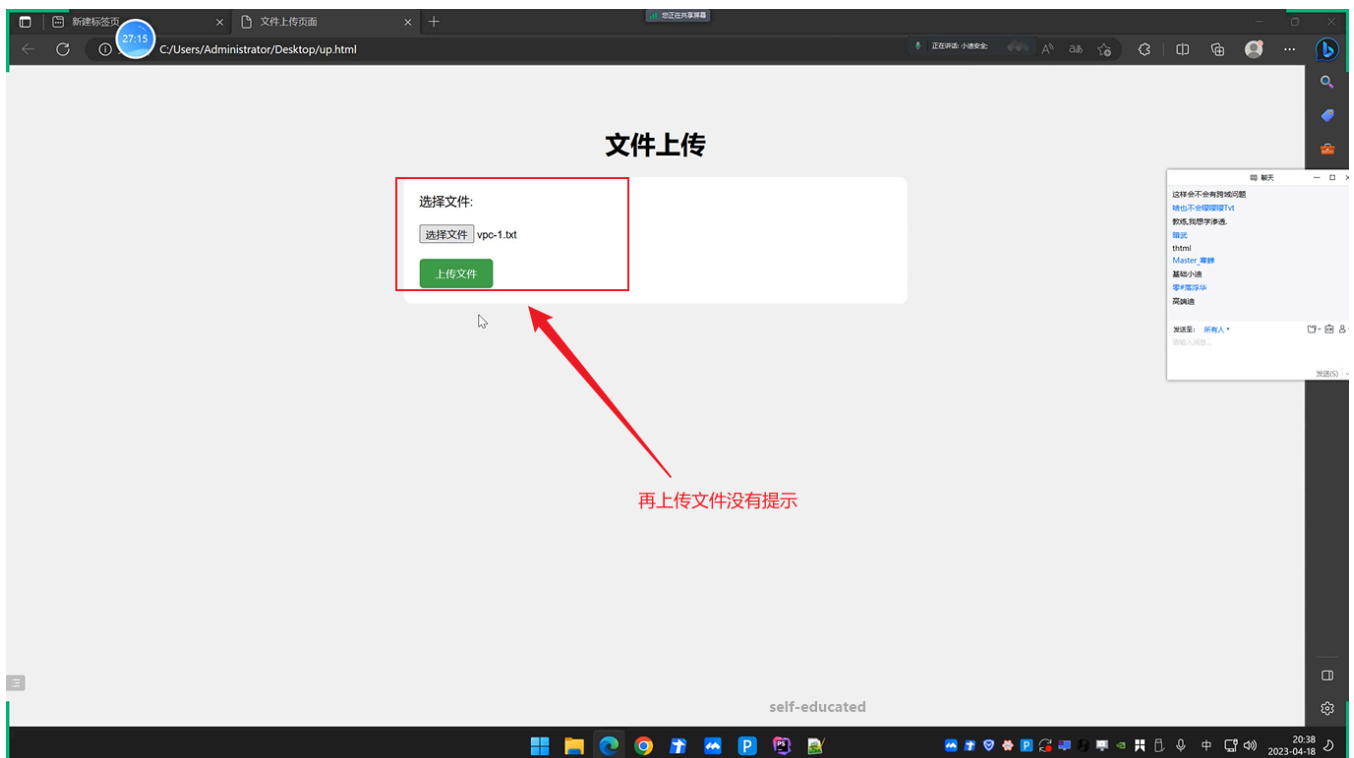
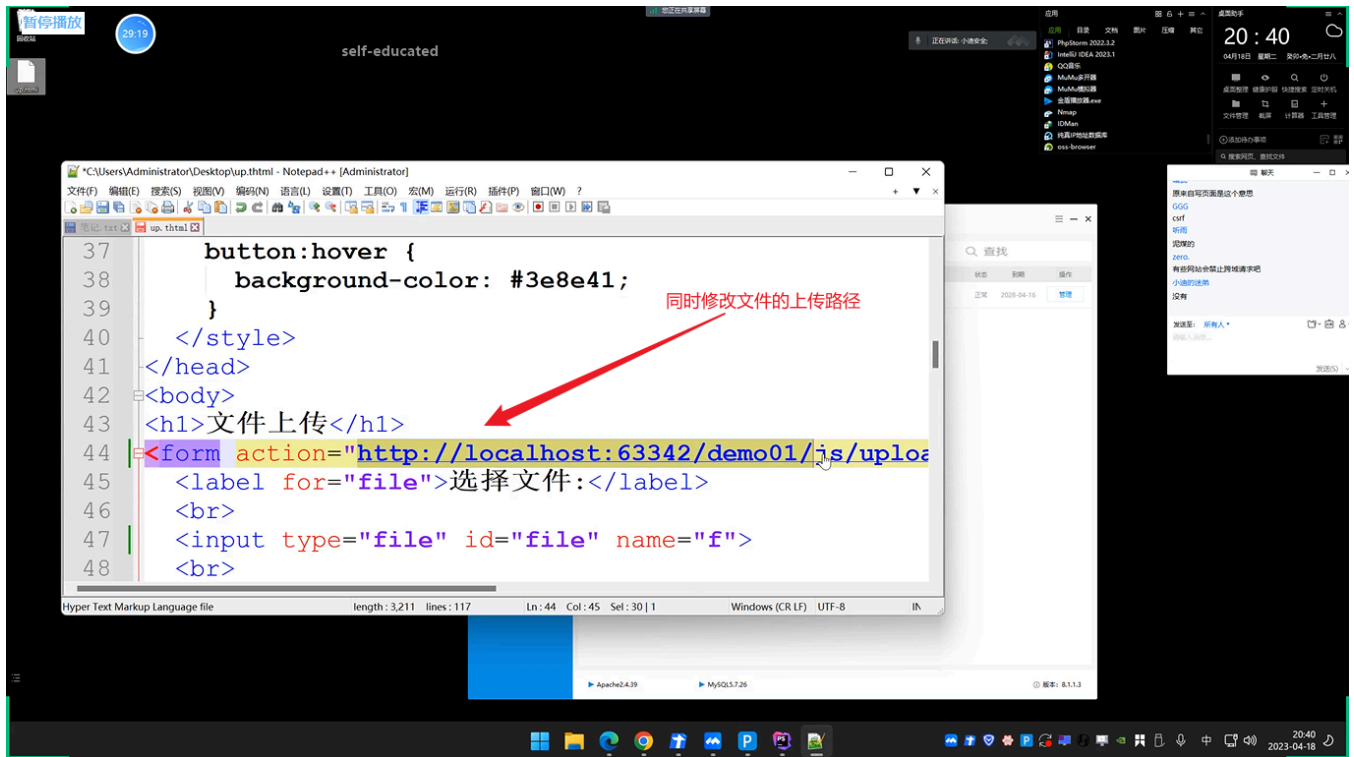
将数据提交给upload.php页面

```
1 <?php
2 $name=$_FILES['f']['name'];
3 $type=$_FILES['f']['type'];
4 $size=$_FILES['f']['size'];
5 $tmp_name=$_FILES['f']['tmp_name'];
6 $error=$_FILES['f']['error'];
7
8 move_uploaded_file($tmp_name, destination: 'upload/'.$name);
```

php页面接收传递过来的值, 将文件进行保存

(4) 安全问题:

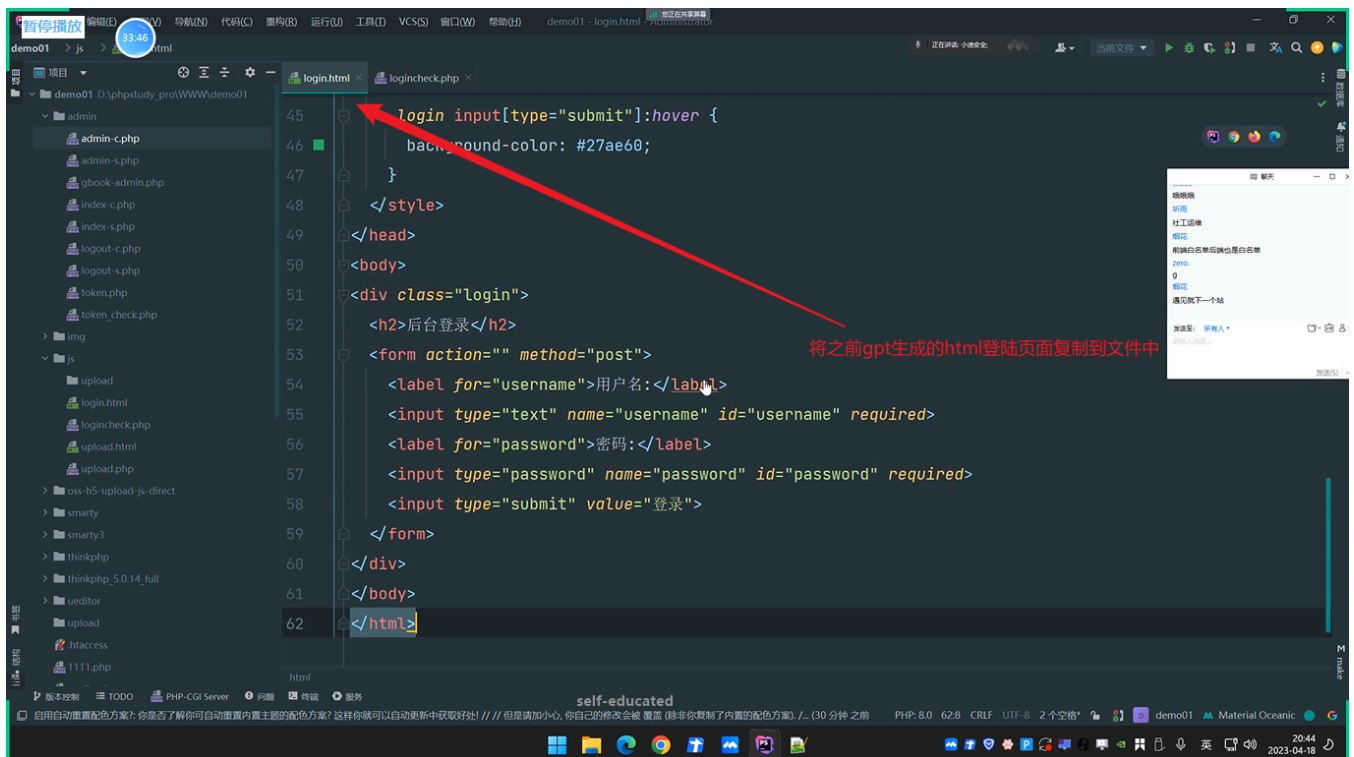




2.2 JS导入库开发-登录验证-JQuery库&Ajax技术

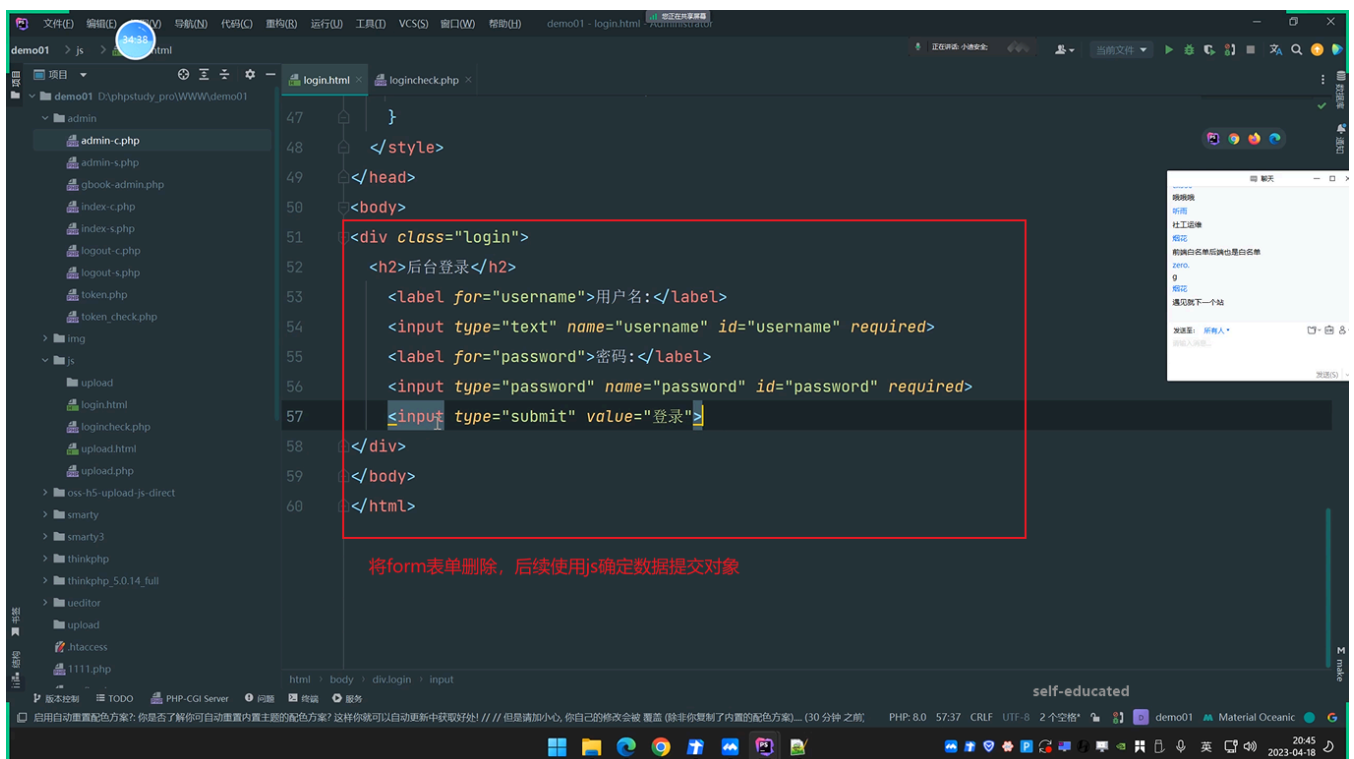
- 0、布置前端页面
- 1、获取登录事件
- 2、配置Ajax请求
- 3、后端代码验证
- 4、成功回调判断
- 6 后端PHP进行帐号判断，前端JS进行登录处理
- 7 架构: html js login.html - logincheck.php

(1) 布置前端页面:



```
45 login input[type="submit"]:hover {
46   background-color: #27ae60;
47 }
48 </style>
49 </head>
50 <body>
51 <div class="login">
52   <h2>后台登录</h2>
53   <form action="" method="post">
54     <label for="username">用户名:</label>
55     <input type="text" name="username" id="username" required>
56     <label for="password">密码:</label>
57     <input type="password" name="password" id="password" required>
58     <input type="submit" value="登录">
59   </form>
60 </div>
61 </body>
62 </html>
```

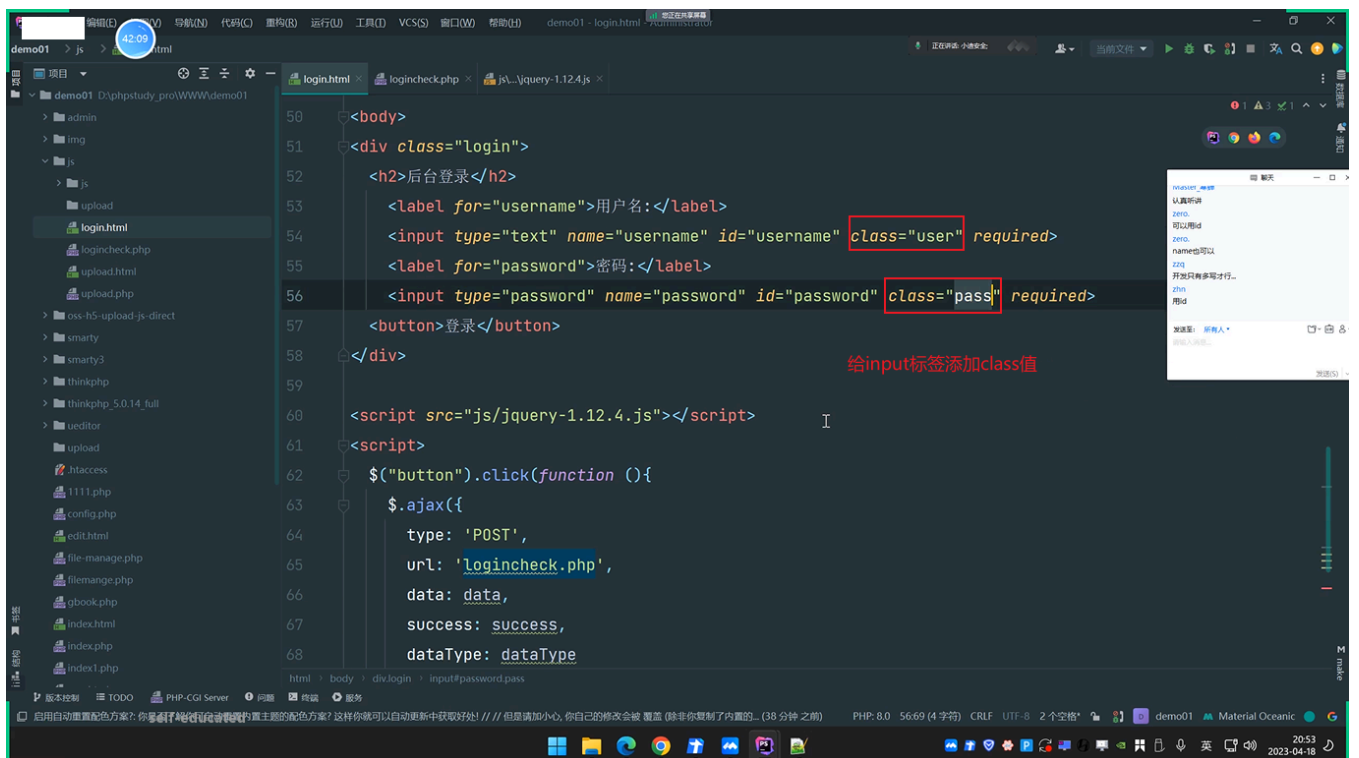
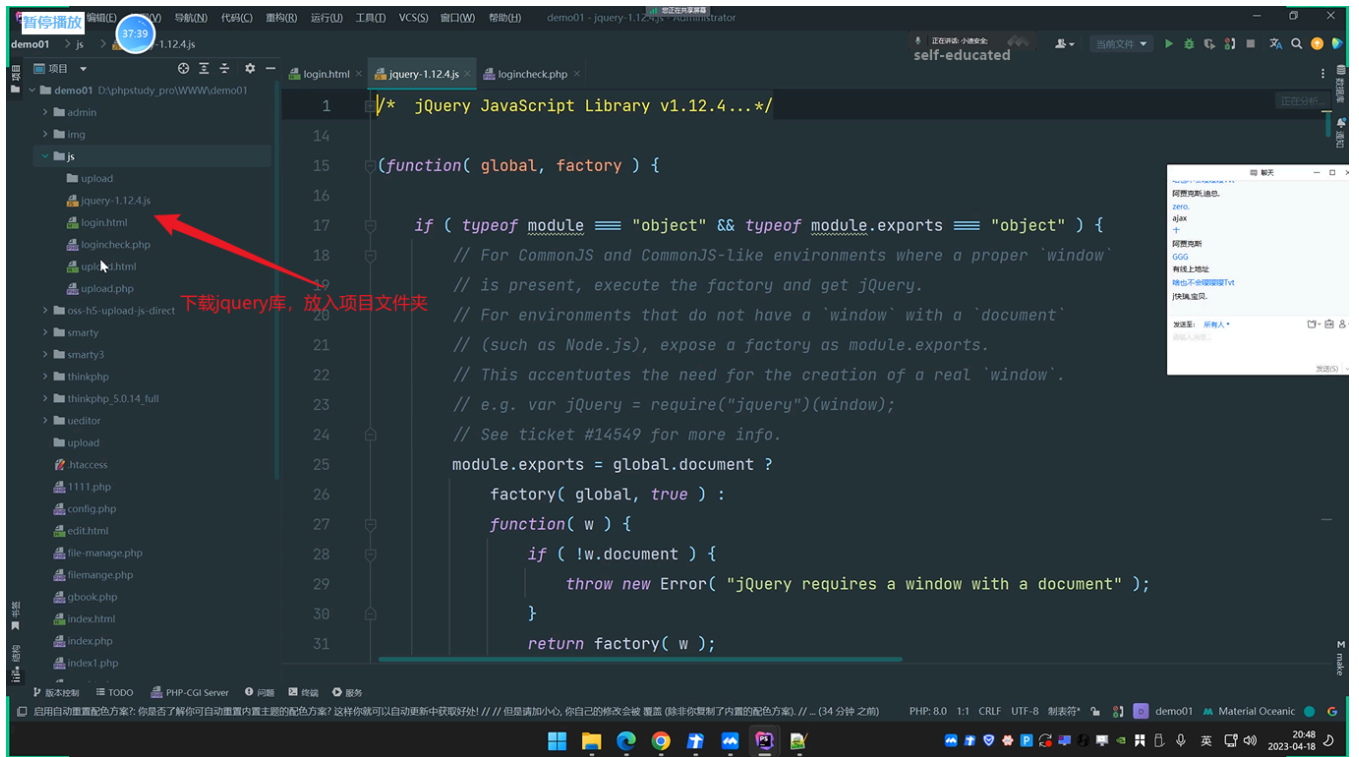
将之前gpt生成的html登陆页面复制到文件中



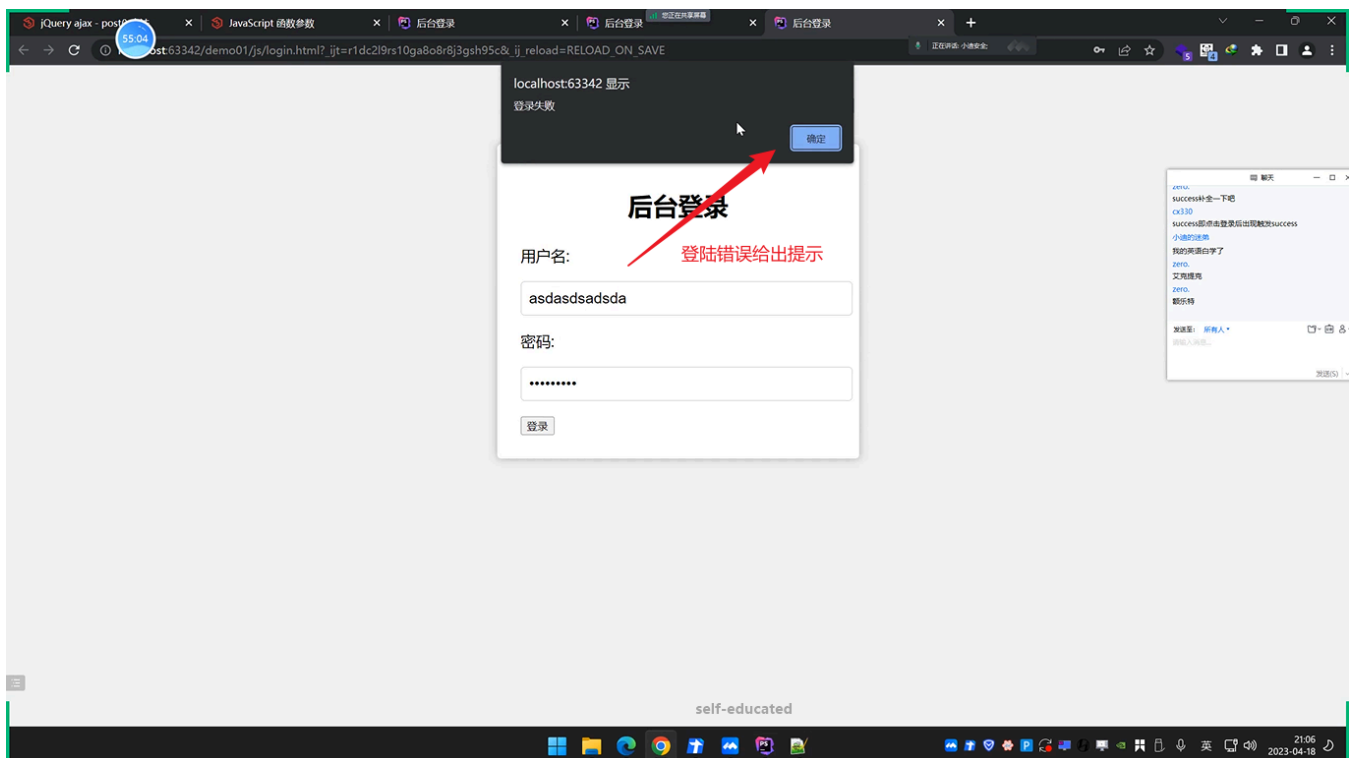
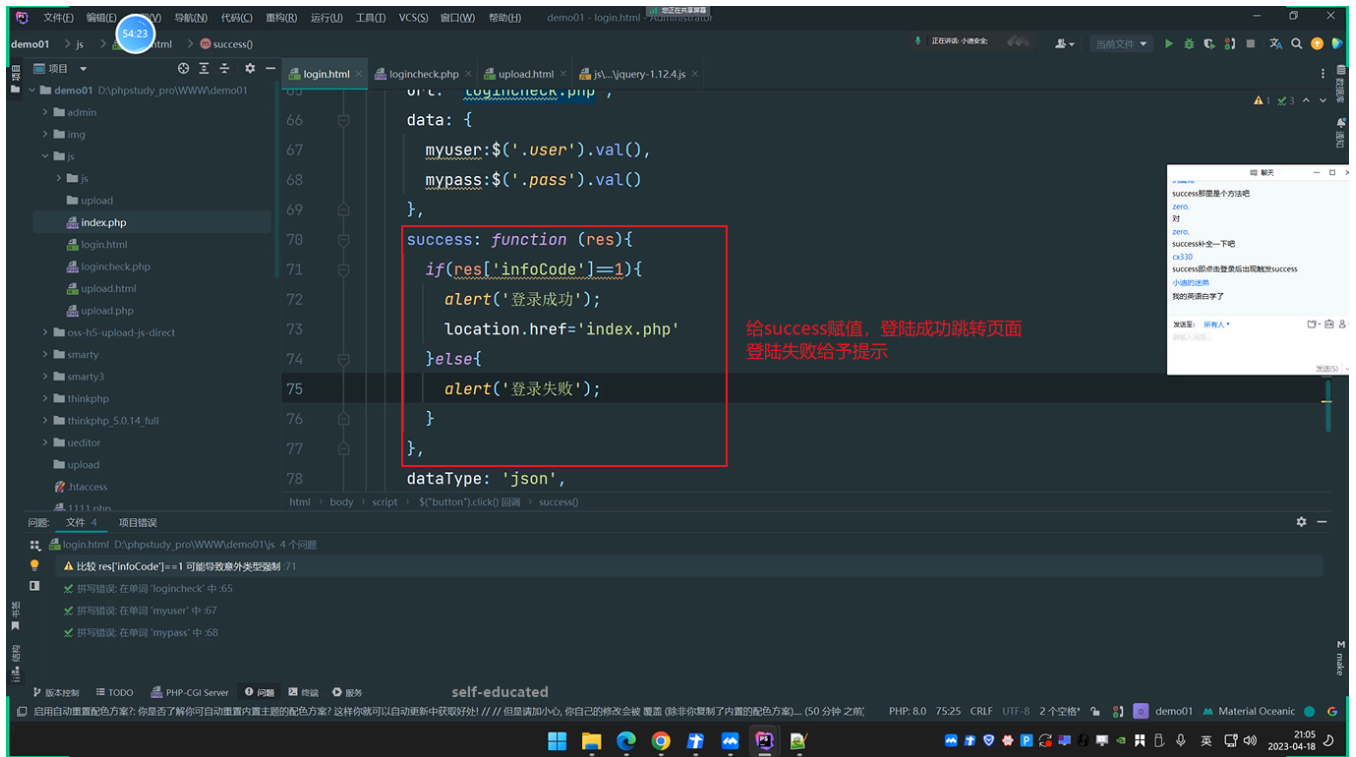
```
47 }
48 </style>
49 </head>
50 <body>
51 <div class="login">
52   <h2>后台登录</h2>
53   <label for="username">用户名:</label>
54   <input type="text" name="username" id="username" required>
55   <label for="password">密码:</label>
56   <input type="password" name="password" id="password" required>
57   <input type="submit" value="登录">
58 </div>
59 </body>
60 </html>
```

将form表单删除，后续使用js确定数据提交对象

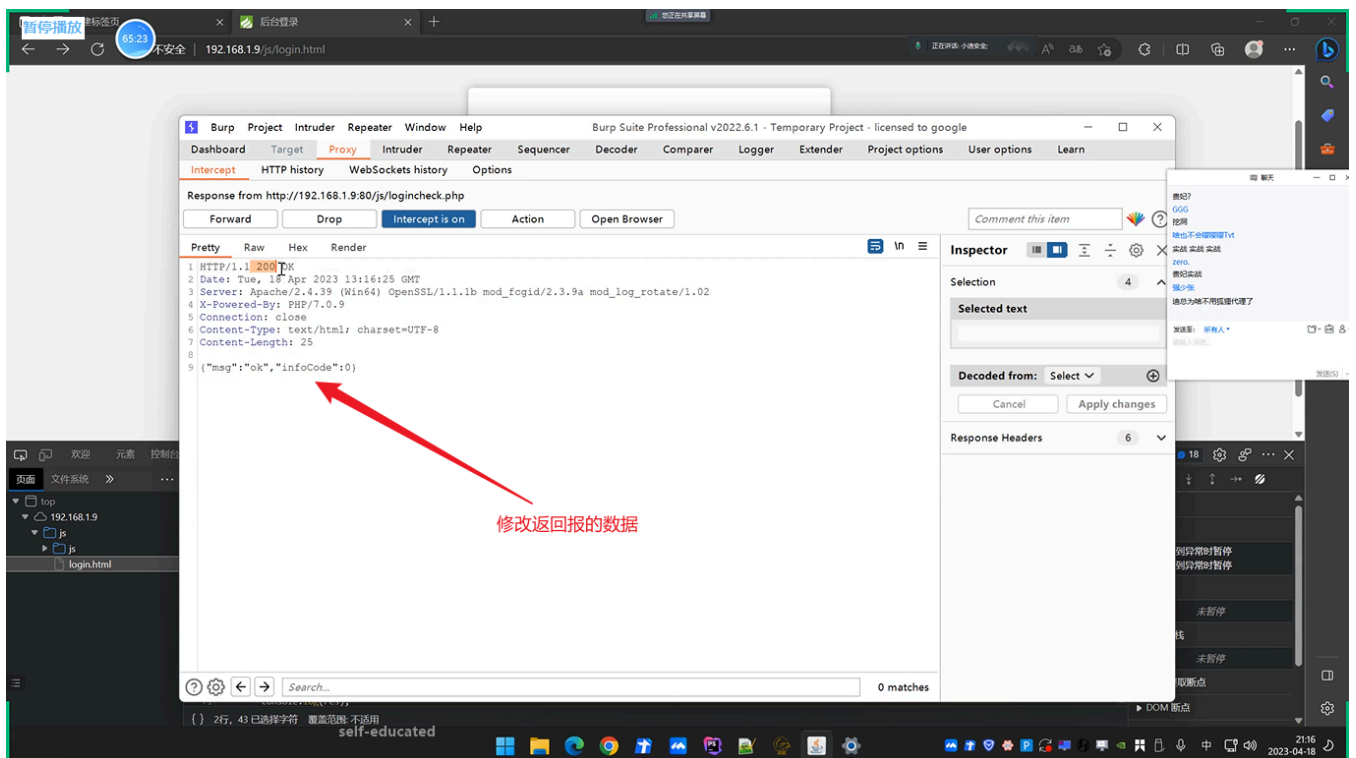
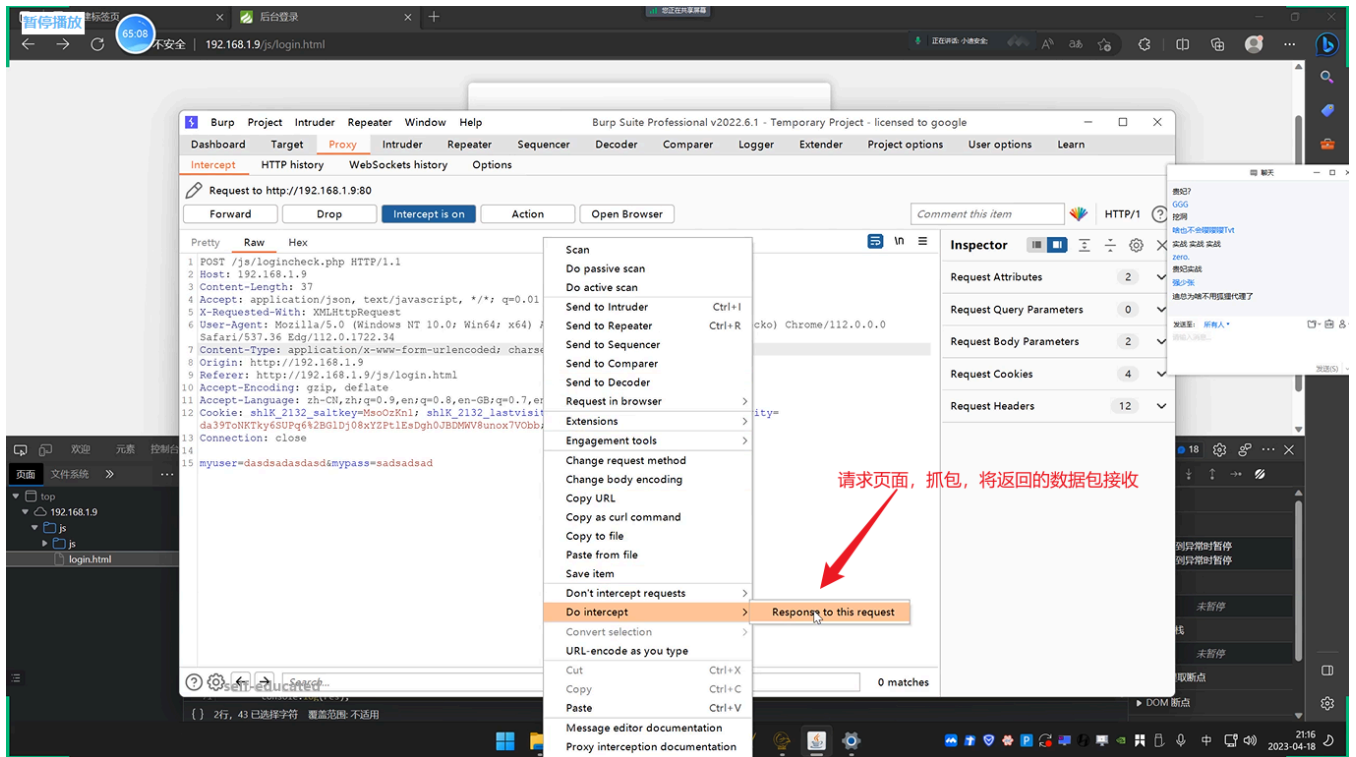
(2) 获取登录事件:

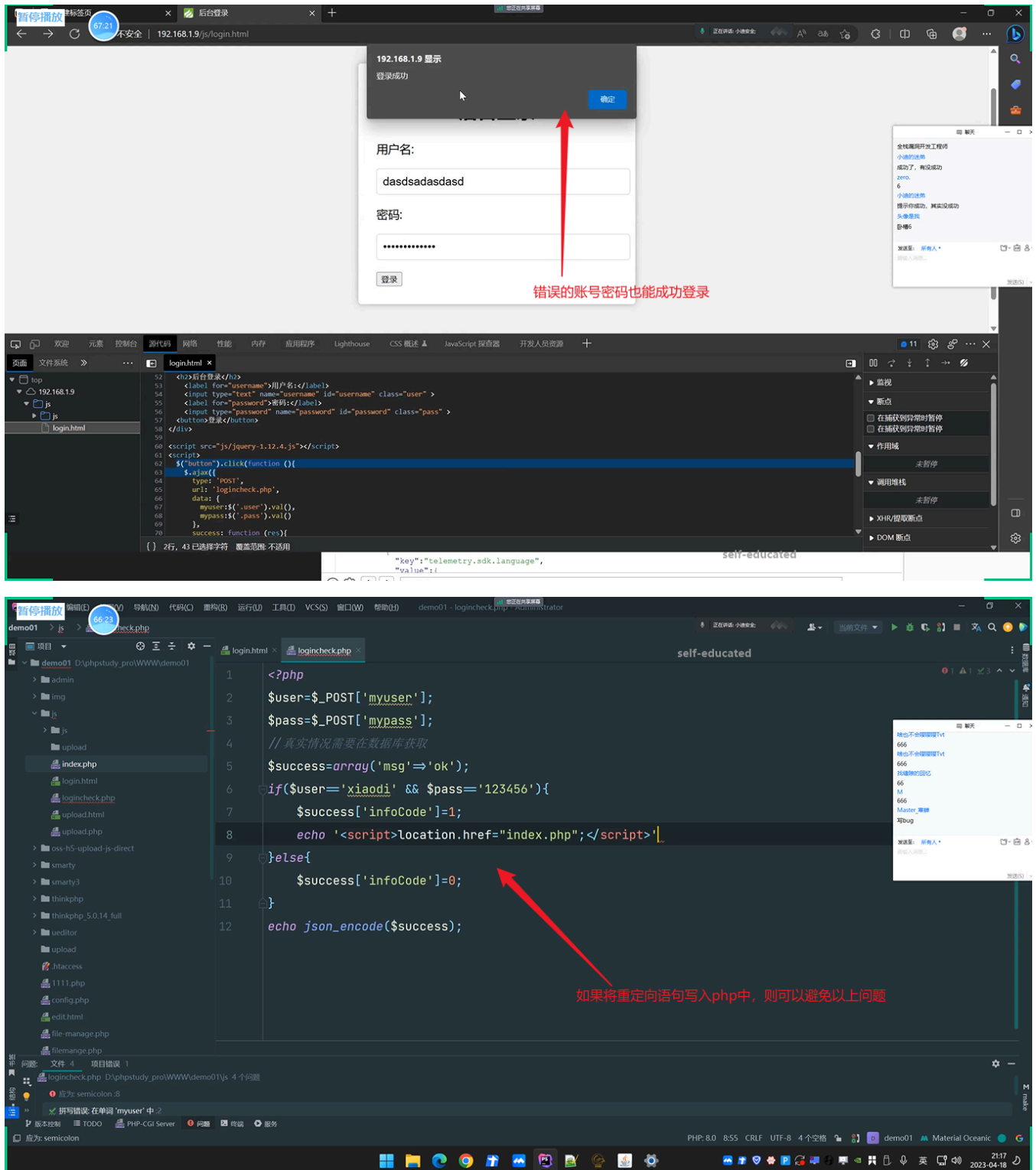


(3) 配置Ajax请求:



(5) 安全问题:

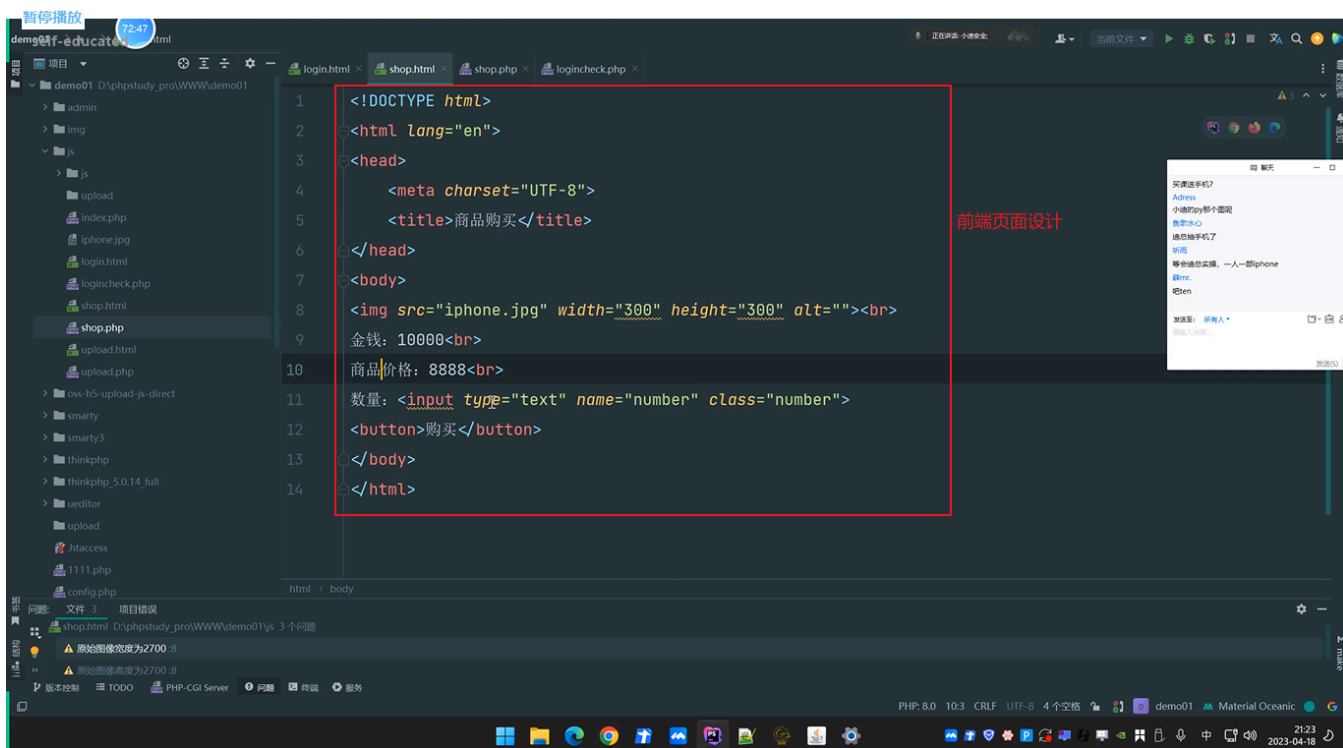




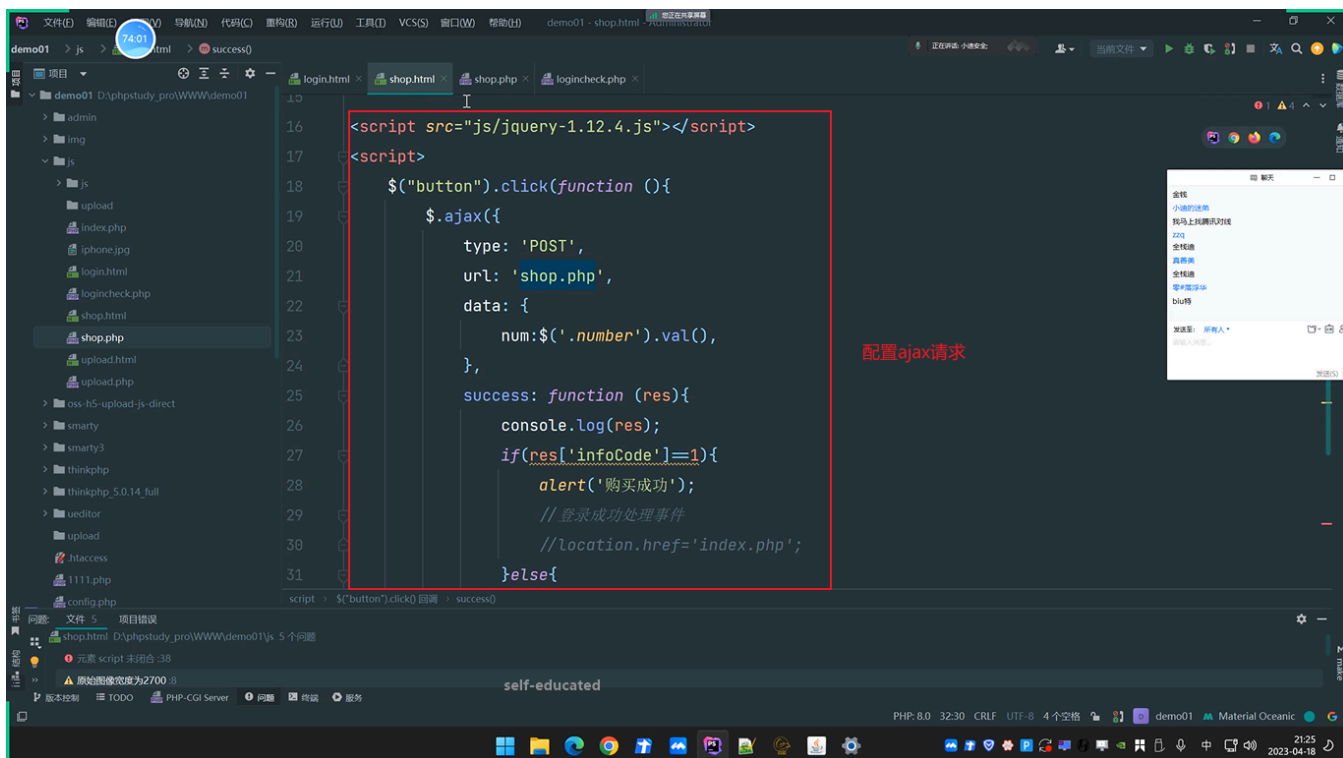
2.3 JS导入库开发-逻辑购买-JQuery库&Ajax技术

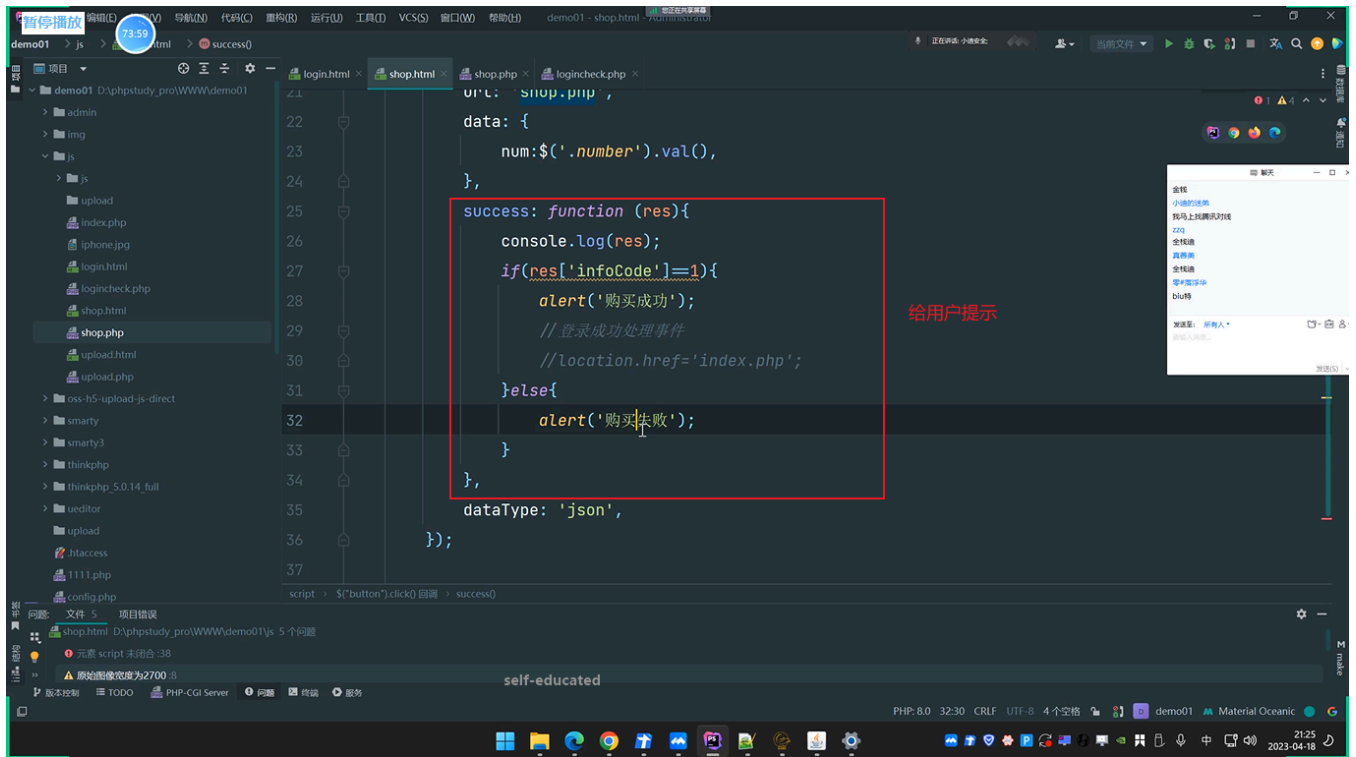
- 1 1、布置前端页面
- 2 2、获取登录事件
- 3 3、配置Ajax请求
- 4 4、后端代码验证
- 5 5、成功回调判断
- 6 架构: html js shop.html - shopcheck.php

(1) 布置前端页面:

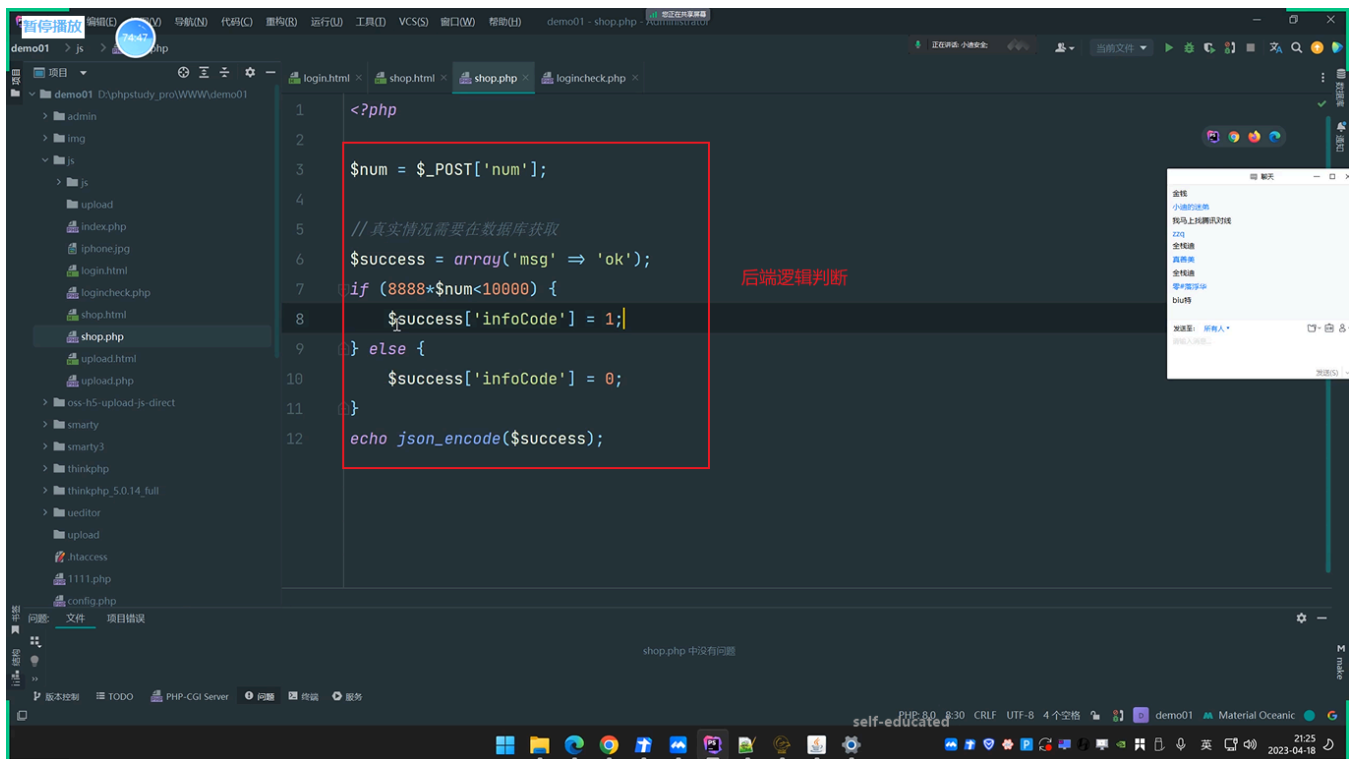


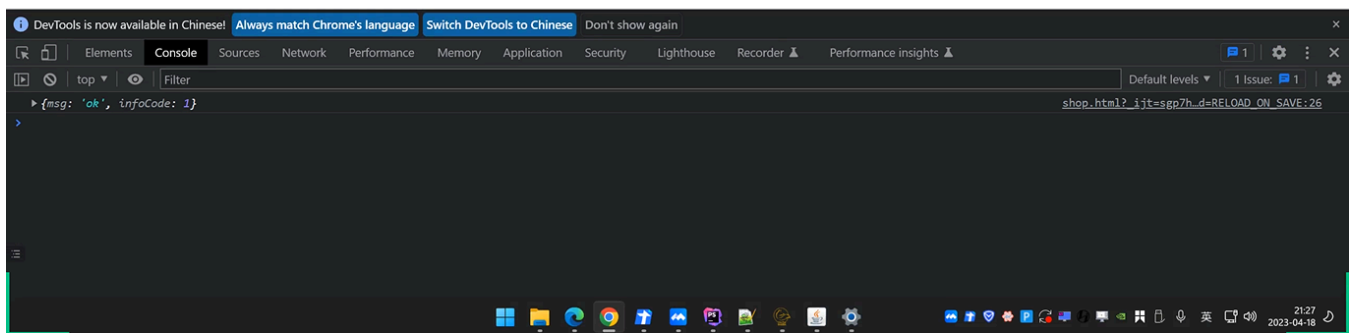
(2) 获取登录事件&&配置Ajax请求:





(3) 后端代码验证&&成功回调判断:





(4) 安全漏洞:

